CS 546
Computer System Security

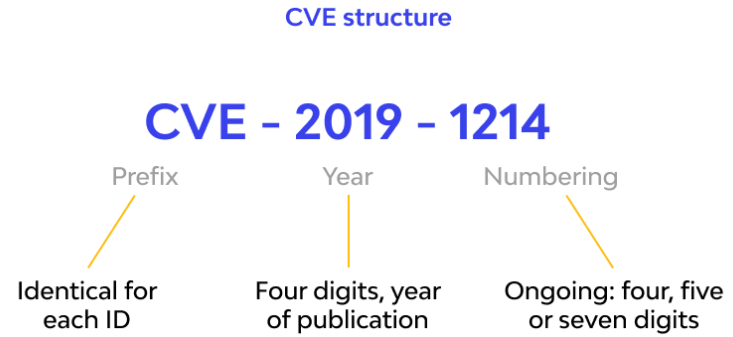
Lecture 8.1: Web Security - III

Instructor: Aarushi Goel

Fall 2026

CVE (Common Vulnerabilities and Exposures)

- CVE (Common Vulnerabilities and Exposures) is a standardized system for identifying and tracking publicly disclosed cybersecurity vulnerabilities in software and hardware.
- Each vulnerability is assigned a unique identifier called a CVE ID.



- An assigned CVE number does not necessarily mean an attack actually happened.
- A vulnerability is a security weakness that could be exploited and CVE ID identifies that vulnerability. An exploit is a technique or code that takes advantage of the vulnerability.

Recent Vulnerabilities and Exploits

(PHP2Shell)

CVE-2026-109618 and CVE-2026-109619

- PHP (PHP: Hypertext Preprocessor) is a programming language primarily used for server-side web development. It allows websites to generate dynamic content, process user requests, interact with databases, and manage user authentication. Unlike JavaScript running in a browser, PHP typically executes on the web server, and the browser receives only the resulting HTML (or other response data).
- PHP2Shell involves two memory-safety vulnerabilities in the PHP interpreter:
  - CVE-2026-109618: Improper handling of out-of-memory errors can leave memory in an uninitialized state.
  - CVE-2026-109619: Stale pointers can reference memory that has already been freed.
- Exploits: In October 2026, researchers reported a campaign chaining PHP2Shell with a Linux privilege-escalation vulnerability to obtain root access on 25 servers, including systems in a U.S. government-affiliated environment.
- Type of Attack: Server-side attack. This is a runtime-level vulnerability as opposed to application-level vulnerability.
- Recovery: Apply PHP security updates immediately.

Recent Vulnerabilities and Exploits

(Adobe Commerce / Magento)

CVE-2026-75650

- Adobe Commerce built over Magento is an e-commerce platform developed by Adobe that allows businesses to create and manage online stores.
- Consider a normal email template:

```
Dear {{ customer_name }},
Your payment could not be processed.
```

- Here {{ customer_name }} is a template instruction that tells the engine to insert the customer's name. The customer name itself should be treated as ordinary text. In the Adobe Commerce vulnerability, attackers manipulated how nested template directives were processed, eventually causing the engine to instantiate a PHP class chosen through attacker-controlled template content. The attacker then abused that functionality to load a file containing malicious PHP code.
- Exploits: Successful exploitation could give attackers control over the web application and access to sensitive information. In September 2026, Adobe confirmed exploitation against merchants, but did not publish a comprehensive monetary-loss figure.
- Type of Attack: Server-side attack. This is a type of code-injection attack, where the programming language interpreter interprets the malicious input.
- Recovery: Prevent untrusted input from becoming executable template expressions, use safe templating APIs and apply the Adobe hotfix.

Recent Vulnerabilities and Exploits

(Adobe Commerce – Stored XSS)

CVE-2026-76200 and CVE-2026-76201

- CVE-2026-76200: An attacker could inject malicious JavaScript into certain fields of an Adobe Commerce website. When another user visited a page displaying that content, the script could execute in their browser and potentially hijack their session or gain elevated privileges. Together, these vulnerabilities could allow the attacker to take control of websites, install webshells, steal database credentials, or modify content.
- CVE-2026-76201: A separate stored XSS vulnerability with similar impact. Adobe has not publicly specified the exact technical difference between them.
- Exploits: Adobe published these vulnerabilities along with security patches on Sept 8; 2026. Adobe stated it was not aware of exploitation in the wild.
- Type of Attack: Stored XSS attack.,
- Recovery: Apply Adobe's patches and other defense mechanisms to protect against XSS attacks

Recent Vulnerabilities and Exploits

(Next.js)

CVE-2025-29927

- Middleware is software that sits between a client and a web application's main logic, processing HTTP requests before they reach the intended endpoint. It can also process responses before they are sent back to the client.
- A specially crafted HTTP request containing the x-middleware-subrequest header could trick vulnerable Next.js applications into skipping middleware execution. If an application relied exclusively on middleware to enforce authentication or authorization, the attacker could reach protected functionality without satisfying those checks.
- Exploits: Unauthorized access to protected resources in vulnerable deployments. The vulnerability was serious, but Vercel's public postmortem did not establish a specific widespread financial loss.
- Type of Attack: Server-side attack. HTTP header abuse.
- Recovery: Upgrade to a patched Next.js release, block externally supplied internal-use middleware headers where appropriate, perform authorization checks within sensitive endpoints and server actions rather than relying exclusively on middleware and audit accesses to restricted resources.

Recent Vulnerabilities and Exploits

(PHP-CGI Argument Injection)

CVE-2024-4577

- A vulnerability in PHP running in CGI mode on certain Windows configurations allowed specially crafted HTTP input to be interpreted as command-line options to the PHP interpreter. Attackers could manipulate PHP's execution behavior and obtain remote code execution.
- Motivation: Deploy ransomware, compromise web servers, steal data, and extort victims.
- Exploits: PHP disclosed the vulnerability in June 2024. Broadcom/Symantec researchers reported that the TellYouThePass ransomware group was exploiting it shortly after disclosure.
- Type of Attack: Server-side attack. Argument injection, unsafe command-line interpretation.
- Recovery: Patch PHP.